



Penetration Testing2



PART 4

Enumeration

Assistant Teacher: Mubarak Altamimi.

LO#01: Explain Enumeration Concepts

What is Enumeration?

- Enumeration involves an attacker **creating active connections with a target system** and **performing directed queries** to gain more information about the target

Counting elements, Objects, items, Usernames, services in Infrastructures

- Attackers use the extracted information to **identify points for a system attack** and **perform password attacks** to gain unauthorized access to information system resources

- Listing shared resources or directories
- Listing the steps in a process
- Counting items in a set and service info.

- Enumeration techniques are conducted in an **intranet environment**

Information Enumerated by Intruders



Network resources



Network shares



Routing tables



Audit and service settings



SNMP and FQDN details



Machine names



Users and groups



Applications and banners

Techniques for Enumeration

1

Extract usernames using
email IDs



2

Extract information using
default passwords



3

Brute force **Active Directory**



4

Extract information using
DNS Zone Transfer



5

Extract **user groups** from
Windows



6

Extract usernames using
SNMP



Services and Ports to Enumerate



TCP/UDP 53

Domain Name System (DNS) Zone Transfer



TCP/UDP 135

Microsoft RPC Endpoint Mapper



UDP 137

NetBIOS Name Service (NBNS)



TCP 139

NetBIOS Session Service (SMB over NetBIOS)



TCP/UDP 445

SMB over TCP (Direct Host)



UDP 161

Simple Network Management Protocol (SNMP)



TCP/UDP 389

Lightweight Directory Access Protocol (LDAP)



TCP 2049

Network File System (NFS)



TCP 25

Simple Mail Transfer Protocol (SMTP)



TCP/UDP 162

SNMP Trap



UDP 500

ISAKMP/Internet Key Exchange (IKE)



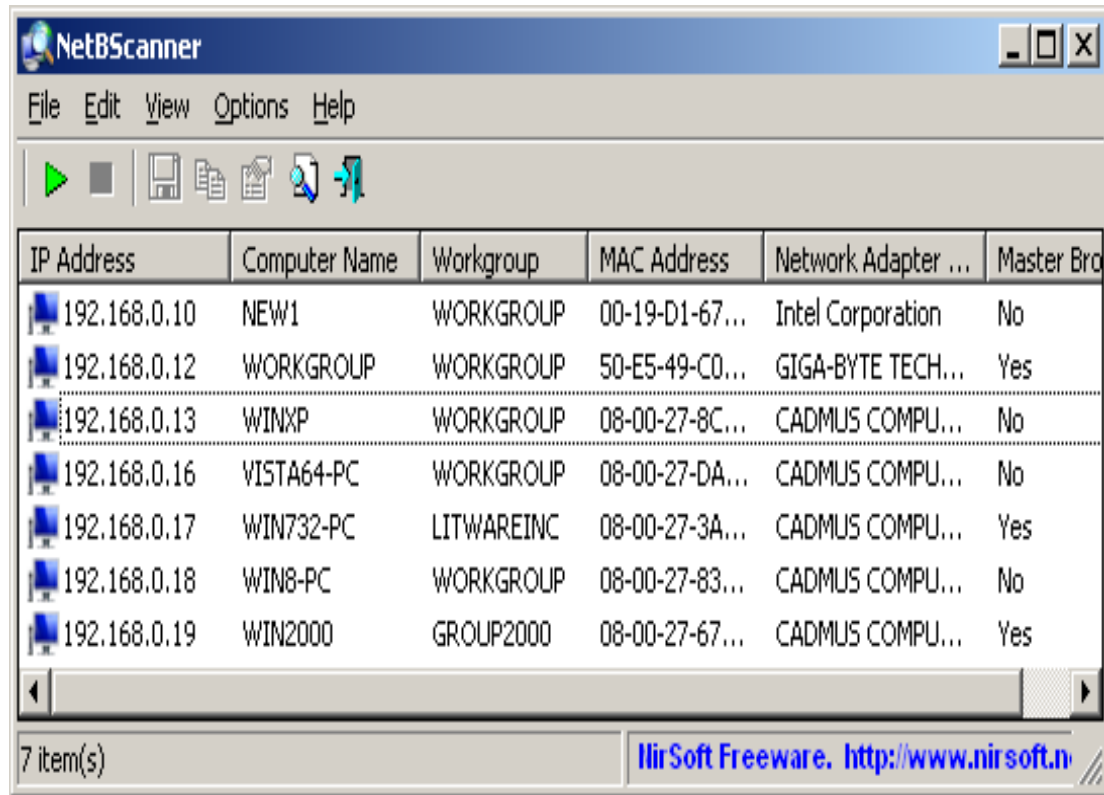
TCP 22

Secure Shell (SSH)

LO#02: Demonstrate Different Techniques for NetBIOS Enumeration

NetBIOS Hint

- (Network Basic Input/Output System) is an industry standard for networking over TCP/IP protocol.
- It grants distributed applications access to each other's network services.
- provides network services to support client-server applications on the network



NetBScanner

File Edit View Options Help

7 item(s)

IP Address	Computer Name	Workgroup	MAC Address	Network Adapter ...	Master Bro
192.168.0.10	NEW1	WORKGROUP	00-19-D1-67...	Intel Corporation	No
192.168.0.12	WORKGROUP	WORKGROUP	50-E5-49-C0...	GIGA-BYTE TECH...	Yes
192.168.0.13	WINXP	WORKGROUP	08-00-27-8C...	CADMUS COMPU...	No
192.168.0.16	VISTA64-PC	WORKGROUP	08-00-27-DA...	CADMUS COMPU...	No
192.168.0.17	WIN732-PC	LITWAREINC	08-00-27-3A...	CADMUS COMPU...	Yes
192.168.0.18	WIN8-PC	WORKGROUP	08-00-27-83...	CADMUS COMPU...	No
192.168.0.19	WIN2000	GROUP2000	08-00-27-67...	CADMUS COMPU...	Yes

NirSoft Freeware. <http://www.nirsoft.net>

```
(ritik@ritik)-[~]
$ netstat -a

Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 ritik:45204             del12s05-in-f4.1e:https ESTABLISHED
tcp        0      0 ritik:49222             server-13-224-20-:https ESTABLISHED
tcp        0      0 ritik:34744             ec2-35-167-149-24:https ESTABLISHED
tcp        0      0 ritik:58126             ec2-35-161-6-128.:https ESTABLISHED
tcp        0      0 ritik:55236             104.18.32.68:http      TIME_WAIT
tcp        0      0 ritik:60936             98.203.120.34.bc.:https ESTABLISHED
tcp        0      0 ritik:43858             104.22.24.131:https    ESTABLISHED
tcp        0      0 ritik:37840             20.120.65.166:https    ESTABLISHED
tcp        0      0 ritik:46330             104.16.122.175:https   ESTABLISHED
udp        0      0 ritik:bootpc            WS-GFGDC01.ad.ge:bootps ESTABLISHED
raw6       0      0 [::]:ipv6-icmp          [::]:*                  7

Active UNIX domain sockets (servers and established)
Proto RefCnt Flags   Type       State   I-Node  Path
unix   2      [ ACC ] STREAM    LISTENING 197448  /run/user/1000/speech-dispatcher/speechd.sock
unix   2      [ ACC ] STREAM    LISTENING 17408   /tmp/.X11-unix/X1
unix   2      [ ACC ] STREAM    LISTENING 19999   @/tmp/.ICE-unix/1182
unix   3      [ ]       DGRAM     CONNECTED 14870   /run/systemd/notify
```

NetBIOS Enumeration

- A NetBIOS name is a unique 16 ASCII character string used to **identify the network devices** over TCP/IP; fifteen characters are used for the **device name**, and the sixteenth character is reserved for the **service or name record type**

NetBIOS name list

Attackers use the NetBIOS enumeration to obtain

- The list of computers that belong to a domain
- The list of shares on the individual hosts in the network
- Policies and passwords

Name	NetBIOS Code	Type	Information Obtained
<host name>	<00>	UNIQUE	Hostname
<domain>	<00>	GROUP	Domain name
<host name>	<03>	UNIQUE	Messenger service running for the computer
<username>	<03>	UNIQUE	Messenger service running for the logged-in user
<host name>	<20>	UNIQUE	Server service running
<domain>	<1D>	GROUP	Master browser name for the subnet
<domain>	<1B>	UNIQUE	Domain master browser name, identifies the primary domain controller (PDC) for the domain

Note: NetBIOS name resolution is not supported by Microsoft for Internet Protocol Version 6 (IPv6)

NetBIOS Enumeration (Cont'd)

netstat\nbtstat



- The nbtstat utility in Windows displays NetBIOS over **TCP/IP** (NetBT) **protocol statistics**, **NetBIOS name tables** for both the local and remote computers, and the **NetBIOS name cache**

- Run the **nbtstat** command "**nbtstat -a <IP address of the remote machine>**" to obtain the NetBIOS name table of a remote computer

To get a services(DNS)table of NetBIOS

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.17763.1158]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\Administrator>nbtstat -a 10.10.1.22

Ethernet 2:
Node IpAddress: [10.10.1.19] Scope Id: []

NetBIOS Remote Machine Name Table

  Name                Type             Status
  -----
SERVER2022            <20>             UNIQUE           Registered
SERVER2022            <00>             UNIQUE           Registered
CEH                   <00>             GROUP            Registered
CEH                   <1C>             GROUP            Registered
CEH                   <1B>             UNIQUE           Registered

MAC Address = 00-15-5D-01-30-02

C:\Users\Administrator>
```

- Run the **nbtstat** command "**nbtstat -c**" to obtain the contents of the NetBIOS name cache, table of NetBIOS names, and their resolved IP addresses

Cmd as admin-netstat\nbtstat→ pro nam,ipAdd, frgn ipAdd, state

```
Administrator: Command Prompt

C:\Users\Administrator>nbtstat -c

Ethernet 2:
Node IpAddress: [10.10.1.19] Scope Id: []

NetBIOS Remote Cache Name Table

  Name                Type             Host Address      Life [sec]
  -----
SERVER2022            <20>             UNIQUE            10.10.1.22        90

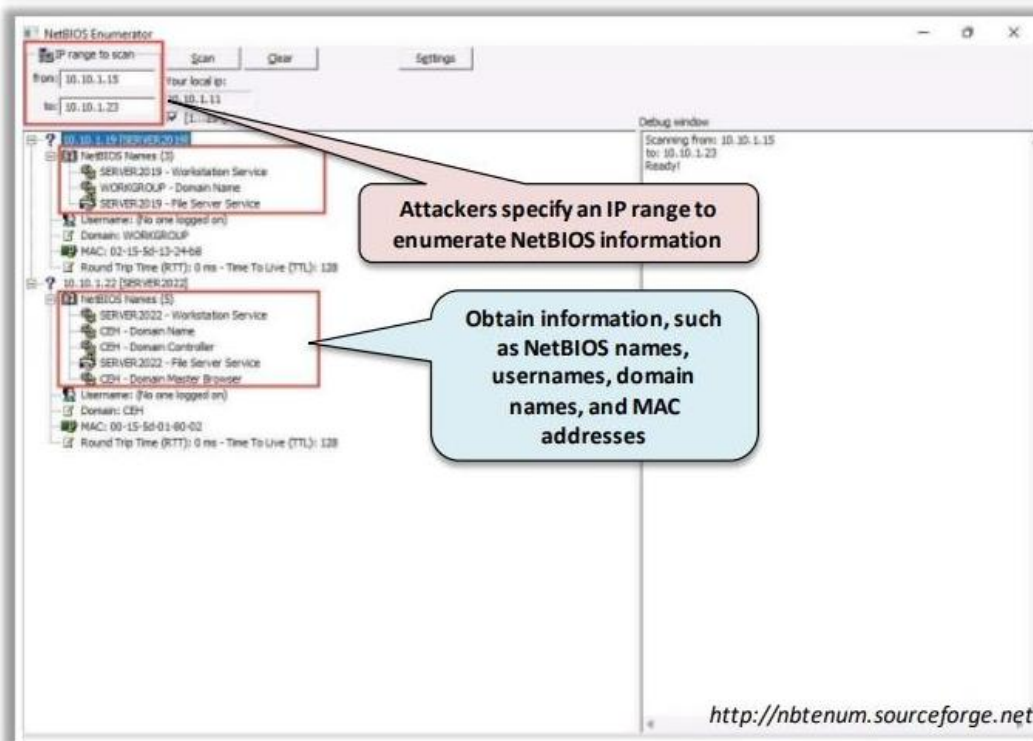
C:\Users\Administrator>
```

<https://docs.microsoft.com>

NetBIOS Enumeration Tools

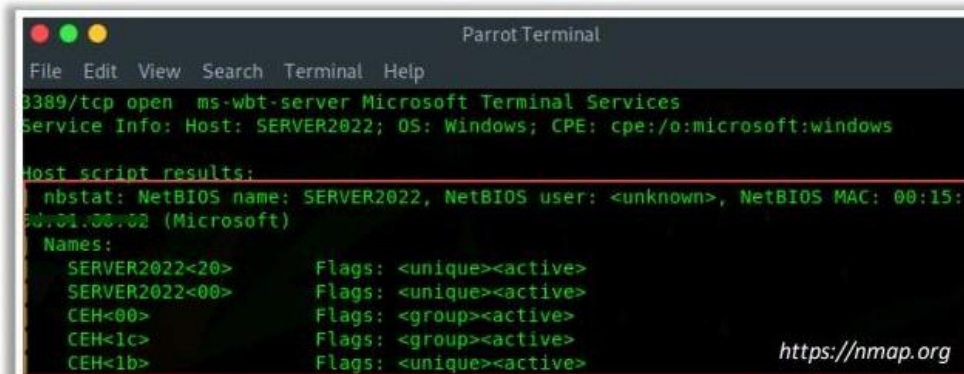
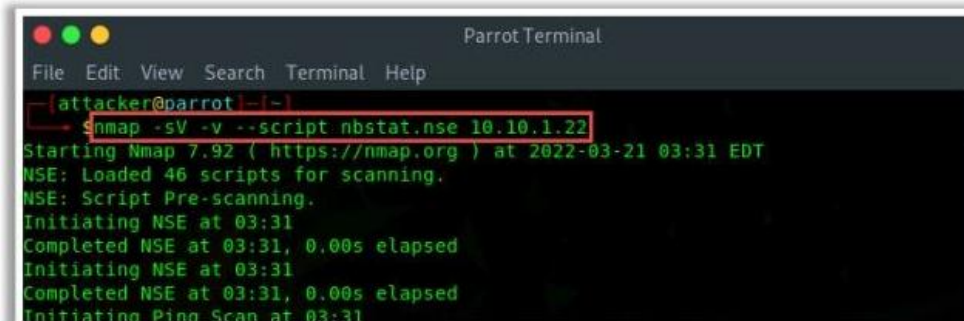
NetBIOS Enumerator

NetBIOS Enumerator helps to enumerate details, such as **NetBIOS names**, **Usernames**, **Domain names**, and **MAC addresses**, for a given range of IP addresses



Nmap

Nmap's nbstat NSE script allow attackers to retrieve targets' **NetBIOS names** and **MAC addresses**



Other NetBIOS Enumeration Tools:

Global Network Inventory
<http://www.magnetosoft.com>

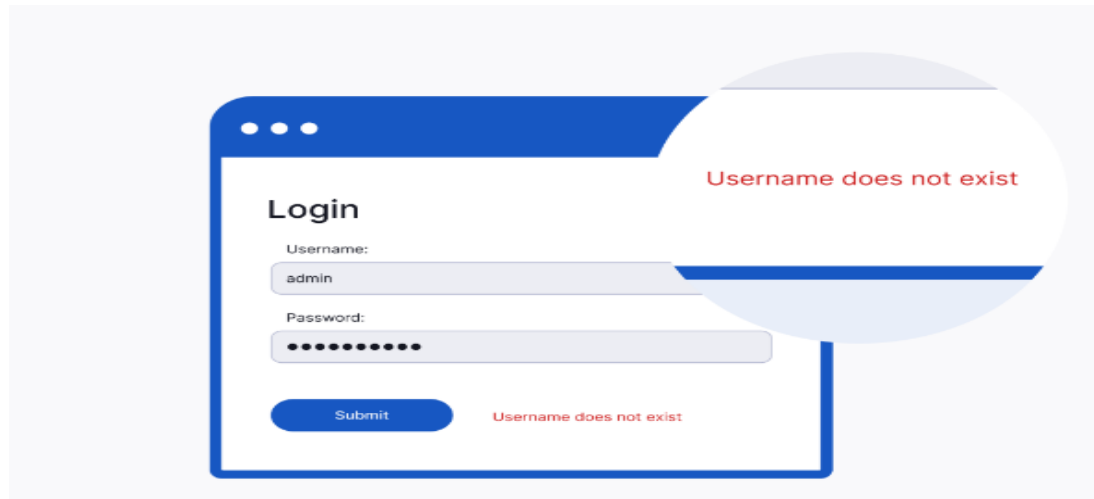
Advanced IP Scanner
<http://www.advanced-ip-scanner.com>

Hyena
<https://www.systemtools.com>

Nsauditor Network Security Auditor
<https://www.nsauditor.com>

Enumerating User account

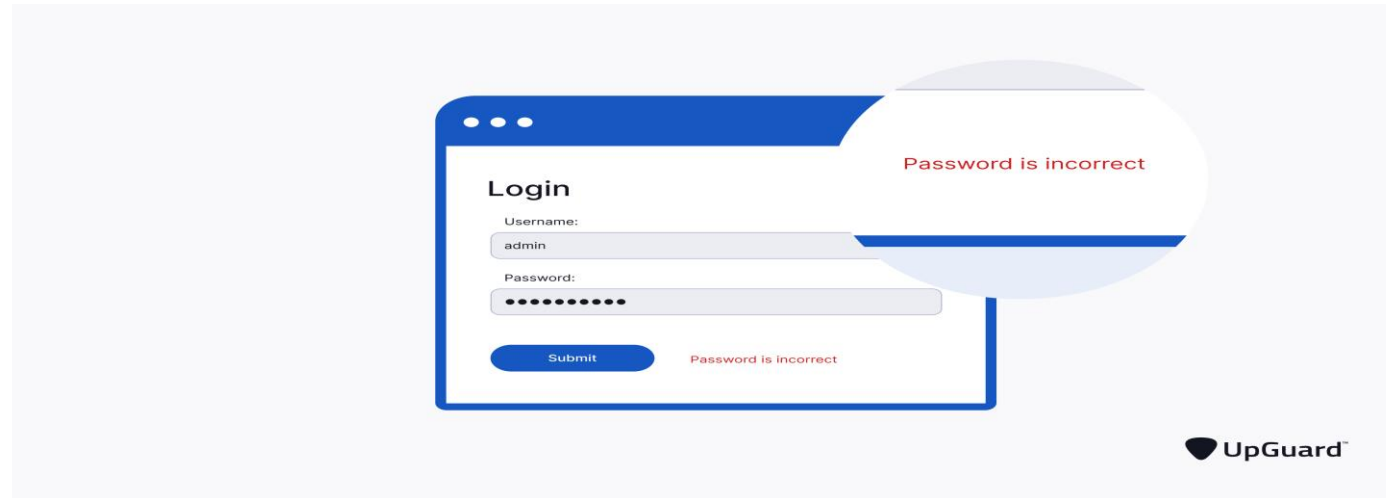
- Is a reconnaissance technique used to gather information about user accounts on a target system, domain, or network.
- This information is useful for penetration testing or malicious purposes.
- Identifying valid usernames for brute-force attacks or privilege escalation
- An attack sequence usually begins by focusing on usernames only.
- The objective at this stage is to find as many valid usernames in a database as possible.
- A webserver with poor application security will identify a non-existent username with an invalid username message similar to this:



Because this message only confirms the validity of the username, a threat actor can confirm that the username is not found on the webserver database.

Enumerating User account

- An Attacker will then **submit the same password with different username** variations until a sufficient list of **validated usernames** is established.
- **Username** variants are either found in purchased lists of leaked credentials **or generated with brute force attack techniques**.
- Cyberattackers will then **repeat the process with passwords, performing brute force techniques** against all validated usernames until a winning combination is finally achieved.



This type of attack can be performed on any web app function that includes database verifications in its processes.

Enumerating User Accounts

- Enumerating user accounts using the **PsTools** suite helps to control and manage remote systems from the command line

<https://learn.microsoft.com/en-us/sysinternals/downloads/psexec>

Cmd → **whoami** , **net localgroup administrators**

Psexec - executes processes remotely

PsList - lists detailed information about processes

PsFile - shows files opened remotely

PsLoggedOn - shows who is logged on locally and via resource sharing

PsGetSid - displays the SID of a computer or user

PsLogList - dumps event log records

Pskill - kills processes by name or process ID

PsPasswd - changes account passwords

PsInfo - lists information about a system

PsShutdown - shuts down and optionally reboots a computer

<https://docs.microsoft.com>

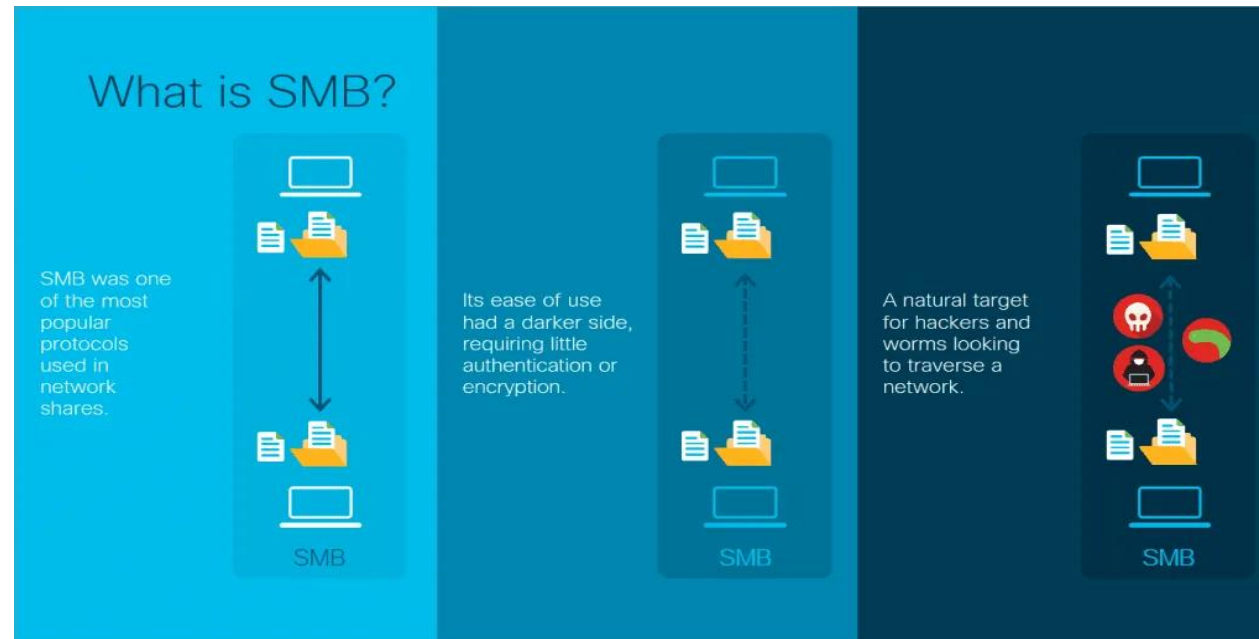
Enumerating shared resources on a network

- Involves discovering and listing **shared files, folders, printers**, or other services that are accessible over SMB (Server Message Block), NFS (Network File System), or other protocols.
- Shared resources can provide potential **entry points for attackers**

Ex. SMB Enumeration

SMB: is a communication protocol developed by Microsoft , **with the purpose of providing shared access to files** and printers across nodes on a network.

- Its one of the most commonly used **protocols for sharing resources** on Windows systems.



Enumerating shared resources on a network

SMB Enumeration

- Involves identifying shared folders, printers, and administrative shares.

--- Using **smbclient** command:

`smbclient -L //<target_ip> -N ,`

* The -L flag lists available shares.

* The -N flag attempts an anonymous connection.

Identifying an SMB Server by Port scanning

```
kali@kali:~/Downloads$ nmap -p 139,445 -Pn 10.10.10.4
Starting Nmap 7.80 ( https://nmap.org ) at 2021-04-16 23:02 PDT
Nmap scan report for 10.10.10.4
Host is up (0.22s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds
kali@kali:~/Downloads$
```

Identifying SMB/OS Version

```
kali@kali:~/Downloads$ nmap -p 139,445 -sV -Pn 10.10.10.4
Starting Nmap 7.80 ( https://nmap.org ) at 2021-04-16 23:02 PDT
Nmap scan report for 10.10.10.4
Host is up (0.22s latency).

PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds  Microsoft Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.47 seconds
kali@kali:~/Downloads$
```

Enumerating Shared Resources Using Net View

- The Net View utility is used to obtain a list of all the **shared resources of a remote host or workgroup**

Net View Commands

- `net view \\<computername>`
- `net view /domain:<domain name>`



```
Administrator: Command Prompt
C:\Users\Administrator>net view \\10.10.1.22 /ALL
Shared resources at \\10.10.1.22
R.hd

Share name  Type  Used as  Comment
-----
ADMIN$      Disk      Remote Admin
C$          Disk      Default share
IPC$        IPC       Remote IPC
NETLOGON    Disk      Logon server share
SYSVOL      Disk      Logon server share
Users       Disk
The command completed successfully.
C:\Users\Administrator>
```

LO#03: Demonstrate Different Techniques for SNMP Enumeration

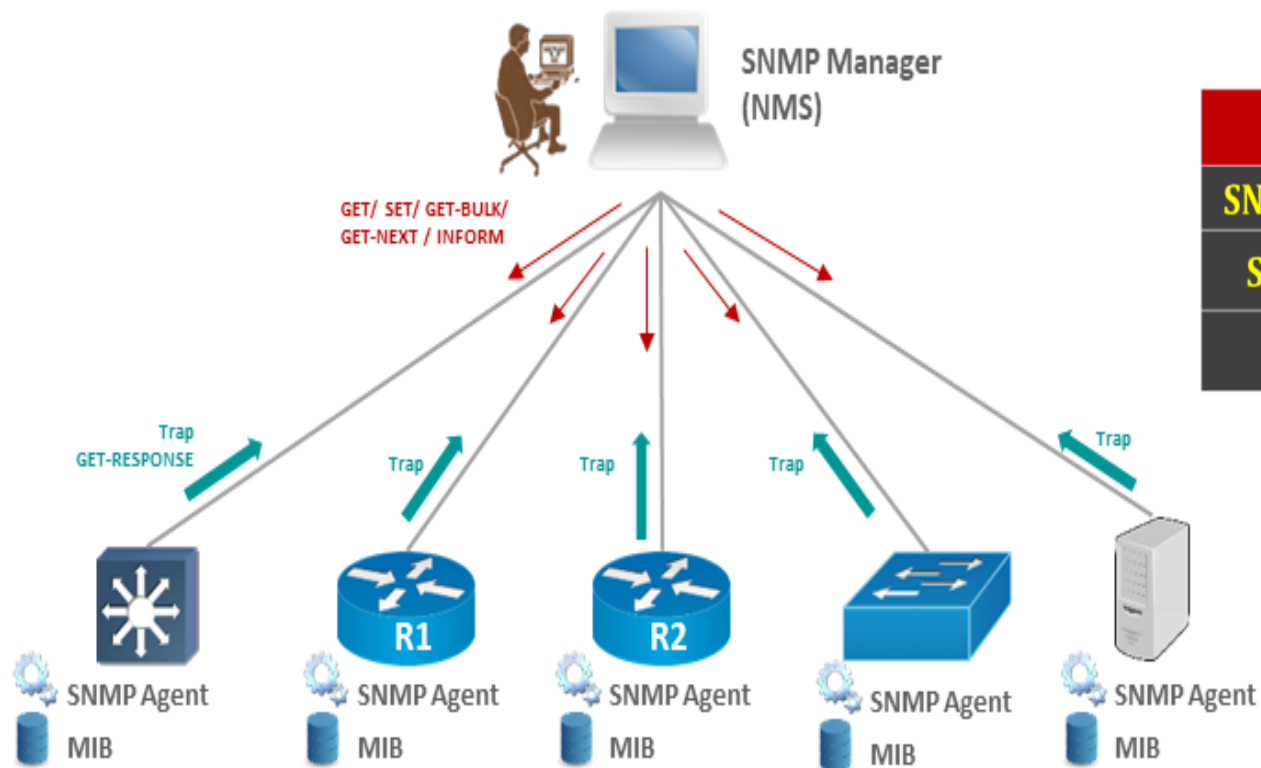
SNMP(Simple Network Management Protocol)

SNMP: is a protocol used for **managing and monitoring devices on IP networks**, such as routers, switches, servers, printers, and other networked hardware.

- **Enables administrators to collect information about the device's configuration, performance, and status.**

- It operates on the application layer.

SNMP Features



SNMP Components

SNMP Components	
SNMP Manager	Centralised Software for Network Management
SNMP Agent	Network Elements (a SW on them) that are managed e.g. routers, switches, servers, hosts, printers, UPSs, etc...
MIB	SNMP Database that makes sure that the data exchange between the Manager and the Agent remains structured

SNMP (Simple Network Management Protocol) Enumeration

- SNMP enumeration is the process of **enumerating user accounts and devices** on a target system using SNMP
- SNMP consists of a **manager** and an **agent**; agents are embedded on every network device, and the manager is installed on a separate computer



- SNMP holds **two passwords** to access and configure the SNMP agent from the management station
 - **Read community string**: It is public by default; it allows for the viewing of the device/system configuration
 - **Read/write community string**: It is private by default; it allows remote editing of configuration



- Attackers use these **default community strings** to extract information about a device
- Attackers enumerate SNMP to extract information about **network resources**, such as hosts, routers, devices, and shares, and **network information**, such as ARP tables, routing tables, and traffic



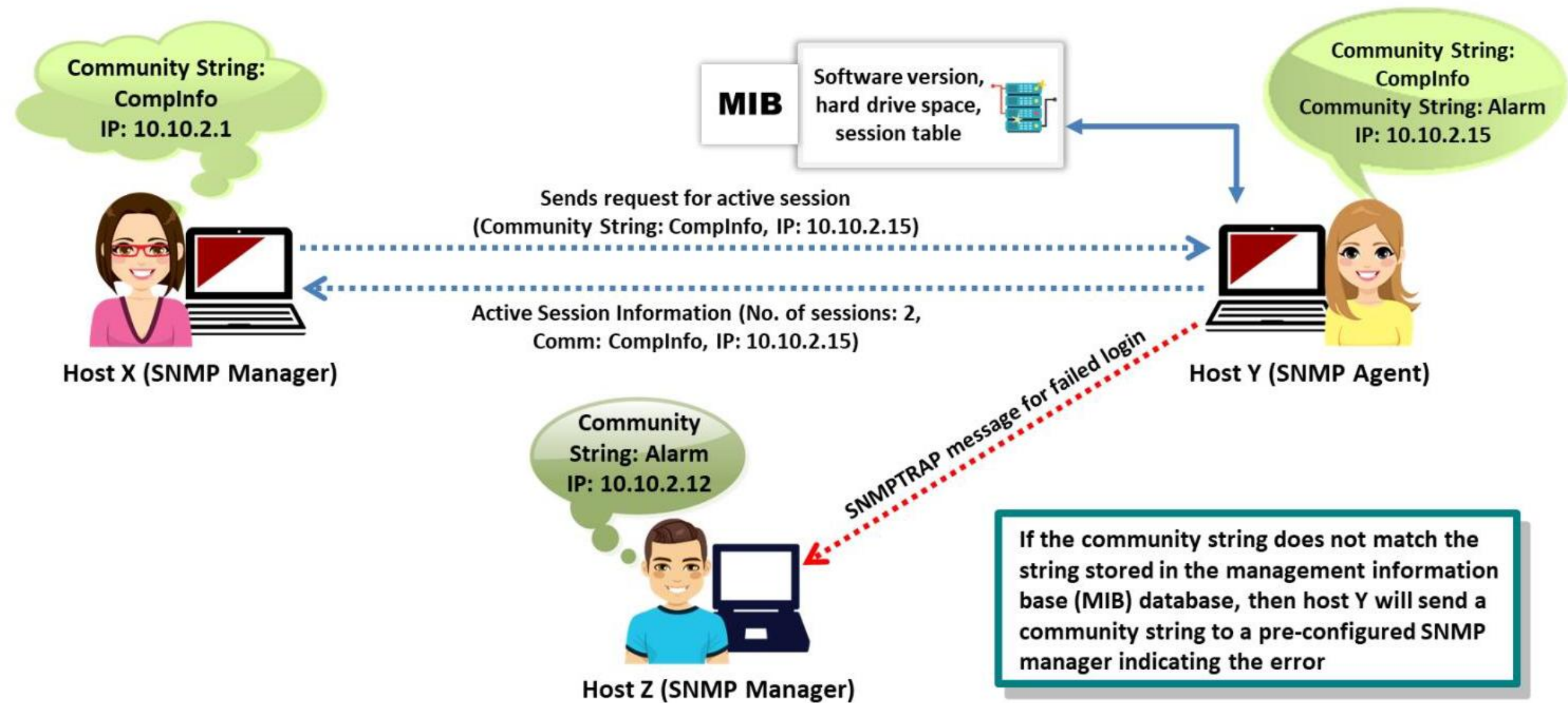


Figure 4.7: Illustration of the working of SNMP

Enumerating SNMP using SnmpWalk and Nmap

SnmpWalk

- SnmpWalk is a command-line tool that allows attackers to **scan numerous SNMP nodes** instantly and **identify a set of variables** that are available for accessing the target network

```
snmpwalk -v1 -c public 10.10.1.22 - Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$ sudo su
[sudo] password for attacker:
[attacker@parrot]~$ snmpwalk -v1 -c public 10.10.1.22
iso.3.6.1.2.1.1.1.0 = STRING: "Hardware: Intel64 Family 6 Model 85 Stepping 7 AT/AT COMPATIBLE - Software: Windows Version 6.3 (Build 20348 Multiprocessor Free)"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.311.1.1.3.1.3
iso.3.6.1.2.1.1.3.0 = Timeticks: (2890071323) 334 days, 11:58:33.23
iso.3.6.1.2.1.1.4.0 = ""
iso.3.6.1.2.1.1.5.0 = STRING: "Server2022.CEH.com"
iso.3.6.1.2.1.1.6.0 = ""
iso.3.6.1.2.1.1.7.0 = INTEGER: 76
iso.3.6.1.2.1.1.8.0 = INTEGER: 24
iso.3.6.1.2.1.2.2.1.1.1 = INTEGER: 1
iso.3.6.1.2.1.2.2.1.1.2 = INTEGER: 2
iso.3.6.1.2.1.2.2.1.1.3 = INTEGER: 3
iso.3.6.1.2.1.2.2.1.1.4 = INTEGER: 4
iso.3.6.1.2.1.2.2.1.1.5 = INTEGER: 5
iso.3.6.1.2.1.2.2.1.1.6 = INTEGER: 6
iso.3.6.1.2.1.2.2.1.1.7 = INTEGER: 7
iso.3.6.1.2.1.2.2.1.1.8 = INTEGER: 8
iso.3.6.1.2.1.2.2.1.1.9 = INTEGER: 9
iso.3.6.1.2.1.2.2.1.1.10 = INTEGER: 10
iso.3.6.1.2.1.2.2.1.1.11 = INTEGER: 11
iso.3.6.1.2.1.2.2.1.1.12 = INTEGER: 12
iso.3.6.1.2.1.2.2.1.1.13 = INTEGER: 13
```

<https://ezfive.com>

Nmap

- Attackers use the **snmp-info NSE script** against an SNMP remote server to retrieve information related to the hosted SNMP services

```
nmap -sU -p 161 --script=snmp-processes 10.10.1.22 - Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$ nmap -sU -p 161 --script=snmp-processes 10.10.1.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-30 00:36 EDT
Nmap scan report for 10.10.1.22
Host is up (0.00069s latency).

PORT      STATE SERVICE
161/udp   open  snmp
snmp-processes:
  1:
    Name: System Idle Process
  4:
    Name: System
  100:
    Name: Registry
  380:
    Name: smss.exe
  460:
    Name: svchost.exe
    Path: C:\Windows\system32\
    Params: -k DcomLaunch -p -s LSM
  500:
    Name: svchost.exe
    Path: C:\Windows\system32\
    Params: -k LocalService -s W32Time
  508:
    Name: csrss.exe
```

<https://nmap.org>

SNMP Enumeration Tools

snmp-check

snmp-check allows one to **enumerate** the **SNMP devices** and place the output in a very **human-readable** and friendly **format**

SoftPerfect Network Scanner

SoftPerfect Network Scanner **discovers** **shared folders** and retrieves practically any information about network devices **via WMI, SNMP, HTTP, SSH, and PowerShell**

```
File Edit View Search Terminal Help
root@parrot:~# snmp-check 10.10.1.22
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 10.10.1.22:161 using SNMPv1 and community 'public'

[*] System information:
Host IP address      : 10.10.1.22
Hostname            : Server2022.CEH.com
Description         : Hardware: Intel64 Family 6 Model 85 Stepp...
Software: Windows Version 6.3 (Build 20348 Multiprocessor Free)
Contact             : -
Location            : -
Uptime snmp         : 01:50:32.79
Uptime system       : 334 days, 10:33:44.95
System date         : 2022-3-25 05:41:08.2
Domain              : CEH

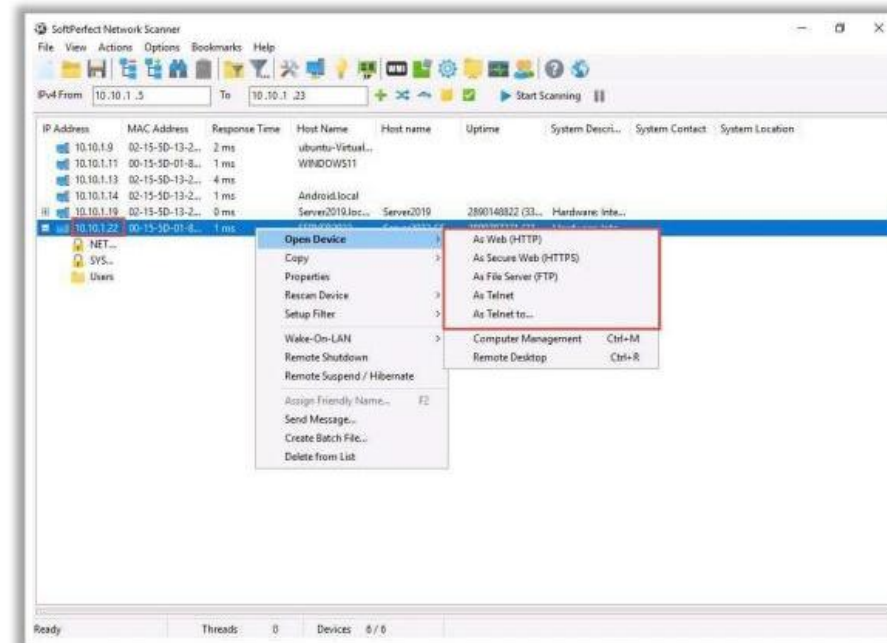
[*] User accounts:
Guest
jason
Martin
Shiela
krbtgt
Administrator

[*] Network information:
IP forwarding enabled : no
Default TTL          : 128
TCP segments received : 71884
TCP segments sent    : 27899
TCP segments retrans : 0
Input datagrams      : 55256
Delivered datagrams  : 55866
Output datagrams     : 20500

[*] Network interfaces:
Interface | [ up ] Software Loopback Interface 1
Id        | 1
Mac Address | 00:00:00:00:00:00
Type      | softwareLoopback
Speed     | 1073 Mbps
MTU       | 1500
In octets | 0
Out octets | 0

Interface | [ down ] Microsoft 8to4 Adapter
Id        | 2
Mac Address | 00:00:00:00:00:00
Type      | unknown
Speed     | 0 Mbps
MTU       | 0
In octets | 0
Out octets | 0
```

<https://www.nothink.org>



<https://www.softperfect.com>

**Other SNMP
Enumeration Tools:**

Network Performance Monitor
<https://www.solarwinds.com>

OpUtils
<https://www.manageengine.com>

PRTG Network Monitor
<https://www.paessler.com>

Engineer's Toolset
<https://www.solarwinds.com>

LO#04: Use Different Techniques for LDAP Enumeration

LDAP Enumeration

- 1** Lightweight directory access protocol (LDAP) is an **Internet protocol** for accessing distributed directory services

Like a **Book with index** of all elements and devices, users and its privileges



- 2** Directory services may provide any organized set of records, often in a **hierarchical** and **logical structure**, such as a corporate email directory

- Service Dir.
- User
- Service Dir.2



- 3** A client starts a LDAP session by connecting to a **directory system agent** (DSA) on TCP port 389 and then sends an operation request to the DSA



- 4** Information is transmitted between the client and server using **basic encoding rules** (BER)



- 5** Attackers query the LDAP service to gather information, such as **valid usernames, addresses**, and **departmental details**, which can be further used to perform attacks



Manual and Automated LDAP Enumeration

Manual LDAP Enumeration

- Attackers perform manual LDAP enumeration using **Python** to **fetch information** such as the domain name, naming context, and directory objects

```
python3 - Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$ sudo su
[sudo] password for attacker:
[root@parrot]~# python3
Python 3.9.2 (default, Feb 28 2021, 17:03:44)
[GCC 10.2.1 20210110] on linux
Type "help", "copyright", "credits" or "license()" for more
>>> import ldap3
>>> server=ldap3.Server('10.10.1.22',get_info=ldap3.ALL,port=389)
>>> connection=ldap3.Connection(server)
>>> connection.bind()
True
>>> server.info
DSA info (from DSE):
Supported LDAP versions: 3, 2
Naming contexts:
DC=CEH,DC=com
CN=Configuration,DC=CEH,DC=com
CN=Schema,CN=Configuration,DC=CEH,DC=com
DC=DomainDnsZones,DC=CEH,DC=com
DC=ForestDnsZones,DC=CEH,DC=com
Supported controls:
1.2.840.113556.1.4.1338 - Verify name - Control - MICROSOFT
1.2.840.113556.1.4.1339 - Domain scope - Control - MICROSOFT
1.2.840.113556.1.4.1340 - Search options - Control - MICROSOFT
1.2.840.113556.1.4.1341 - RODC DCPROMO - Control - MICROSOFT
1.2.840.113556.1.4.1413 - Permissive modify - Control - MICROSOFT
1.2.840.113556.1.4.1504 - Attribute scoped query - Control - MICROSOFT
1.2.840.113556.1.4.1852 - User quota - Control - MICROSOFT
```

Automated LDAP Enumeration

- Attackers use the **ldap-brute NSE script** to brute-force LDAP authentication

```
nmap -p 389 --script ldap-brute --script-args ldap.base='cn=users,dc=CEH,dc=com' 10.10.1.22 - Parrot Terminal
File Edit View Search Terminal Help
PORT      STATE SERVICE
389/udp    open  ldap
MAC Address: 00:15:5D:01:80:02 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
[root@parrot]~# nmap -p 389 --script ldap-brute --script-args ldap.base='cn=users,dc=CEH,dc=com' 10.10.1.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-29 06:09 EDT
Nmap scan report for 10.10.1.22
Host is up (0.0014s latency).

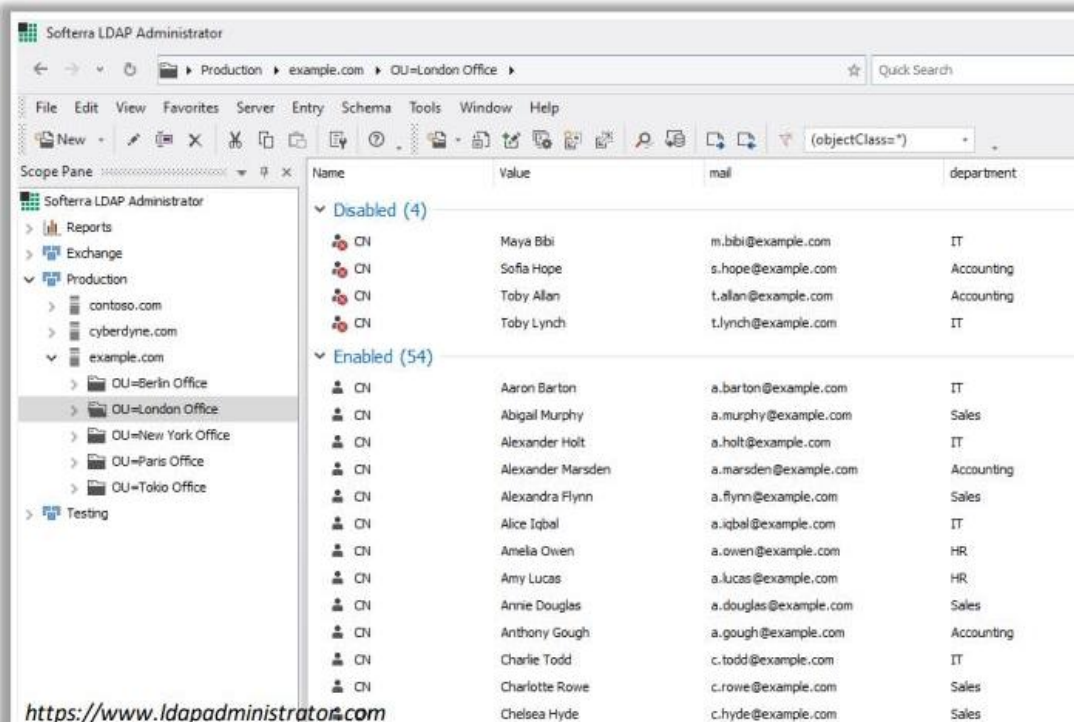
PORT      STATE SERVICE
389/tcp    open  ldap
| ldap-brute:
|   cn=root,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=admin,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=administrator,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=webadmin,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=sysadmin,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=netadmin,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=guest,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=user,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=web,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|   cn=test,cn=users,dc=CEH,dc=com:<empty> => Valid credentials
|_ MAC Address: 00:15:5D:01:80:02 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 0.46 seconds
```

LDAP Enumeration Tools

Softerra LDAP Administrator

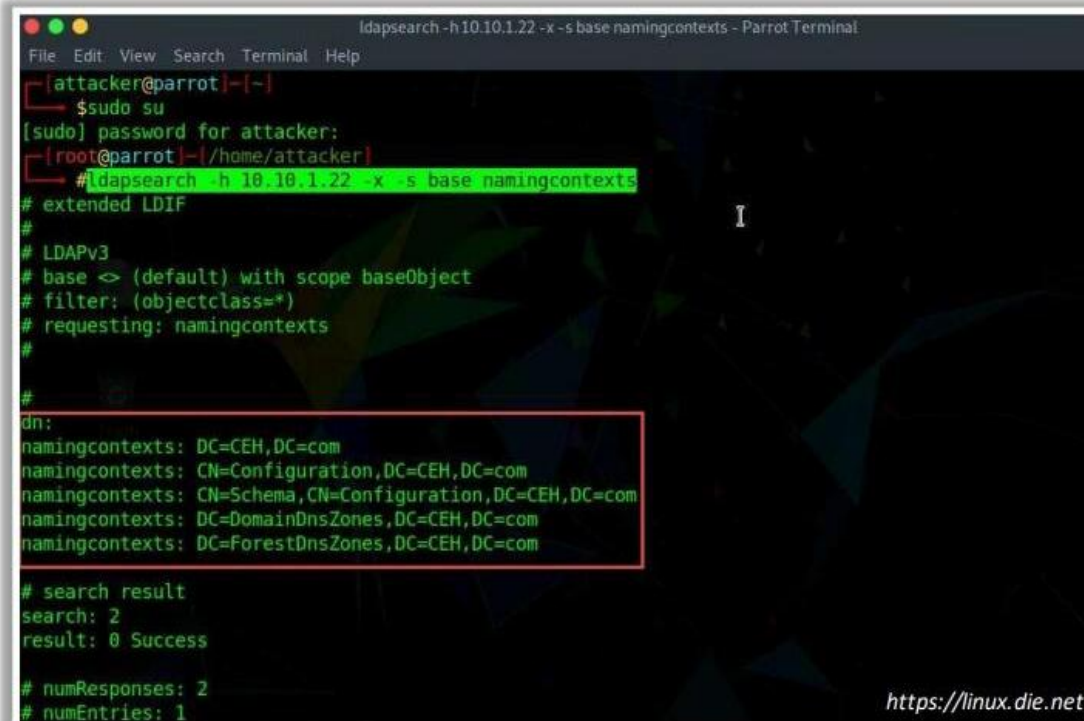
Softerra LDAP Administrator provides various features essential for **LDAP development**, deployment, and the **administration of directories**



<https://www.ldapadministrator.com>

ldapsearch

Attackers use ldapsearch for **enumerating AD users**. It allows attackers to establish a connection with an LDAP server to perform different searches using specific filters



<https://linux.die.net>

Other LDAP Enumeration Tools:

AD Explorer

<https://docs.microsoft.com>

LDAP Admin Tool

<https://www.ldapsoft.com>

LDAP Account Manager

<https://www.ldap-account-manager.org>

LDAP Search

<https://securityxploded.com>

LO#05: Use Different Techniques for NTP and NFS Enumeration

NTP Enumeration



Network Time Protocol (NTP) is designed to **synchronize the clocks of networked computers**

Levels:-
-Stratum0
..
-Stratum15



It uses **UDP port 123** as its primary means of communication



NTP can maintain time to within **10 milliseconds (1/100 second)** over the public Internet



It can achieve accuracies of **200 microseconds** or better in local area networks under ideal conditions

Attackers query the NTP server to gather valuable information, such as

- List of **connected hosts**
- **Clients IP addresses** in a network, their system names, and OSs
- **Internal IPs** can also be obtained if the NTP server is in the demilitarized zone (DMZ)



NTP Enumeration Commands

ntptrace

- Traces a chain of NTP servers back to the primary source
- `ntptrace [-n] [-m maxhosts] [servername/IP_address]`

ntpd

- Monitors operation of the NTP daemon, ntpd
- `ntpd [-ilnps] [-c command] [host] [...]`

ntp

- Monitors NTP daemon (ntpd) operations and determines performance
- `ntp [-inp] [-c command] [host] [...]`

```

ntpd - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#ntpd
ntpd> ?
ntpd commands:
addpeer      controlkey  fudge      keytype    quit       timeout
addrefclock  ctlstats   help       listpeers  readkeys   timerstats
addserver    debug      host       loopinfo   requestkey traps
addtrap      delay      hostnames  memstats   reset      trustedkey
authinfo     delrestrict ifreload   monlist    reslist    unconfig
broadcast    disable    ifstats    passwd     restrict   unrestrict
clkbug       dmpeers    iostats    peers      showpeer   untrustedkey
clockstat    enable     kerninfo   preset     sysinfo    version
clrtrap      exit       keyid      pstats     sysstats
ntpd>

```

These ntpdc queries can be used to obtain additional NTP server information

```

ntp - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#ntp
ntp> ?
ntp commands:
:config      drefid     mreadlist  readvar
addvars      exit       mreadvar   reslist
apeers       help       mrl         rl
associations host       mrulist    rmvars
authenticate hostnames  mrv         rv
authinfo     ifstats    ntpversion saveconfig
cl           iostats    opeers      showvars
clearvars    kerninfo   passwd      sysinfo
clocklist    keyid      passwd     sysstats
clockvar     keytype    peers       timeout
config-from-file associations poll        timerstats
cooked       lpeers     pstats     version
cv           lpassociations quit        writelist
debug        lpeers     raw         writevar
delay        monstats   readlist
ntp>

```

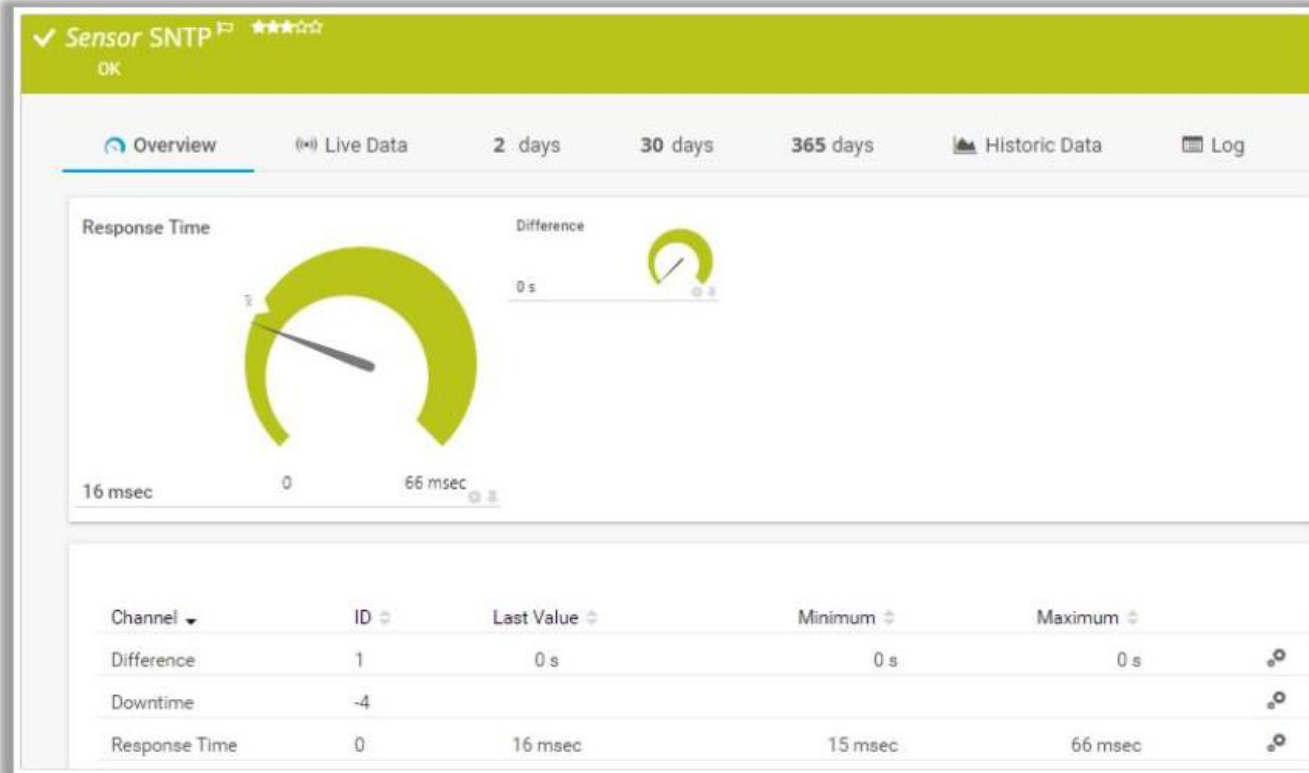
These ntpq queries can be used to obtain additional NTP server information

NTP Enumeration Tools

- **PRTG Network Monitor** includes **SNTP Sensor monitor**, a simple network time protocol (SNTP) server that shows the response time of the server and time difference in comparison to the local system time

NTP Enumeration Tools

- Nmap (<https://nmap.org>)
- Wireshark (<https://www.wireshark.org>)
- udp-proto-scanner (<https://labs.portcullis.co.uk>)
- NTP Server Scanner (<http://www.bytefusion.com>)



<https://www.paessler.com>

NFS Enumeration

Network file sys. Pro.

- The NFS system is generally implemented on the computer network, where the **centralization of data** is required for critical resources
Allow the client to access the file over the Net. Look like on it.
Support sharing files over various OS.

- NFS enumeration enables attackers to identify the **exported directories**, **list of clients** connected to the NFS server along with their **IP addresses**, and the **shared data** associated with the IP addresses
MOUNTING.

showmount command

```

Parrot Terminal
Close Window ew Search Terminal Help
[attacker@parrot]~$ showmount -e 10.10.1.9
Export list for 10.10.1.9:
/home *
[attacker@parrot]~$
  
```

Shared folder

rpcinfo command

```

ubuntu@ubuntu-Virtual-Machine: ~
ubuntu@ubuntu-Virtual-Machine:~$ rpcinfo -p 10.10.1.19
  program vers proto  port  service
  100000    2    udp    111   portmapper
  100000    3    udp    111   portmapper
  100000    4    udp    111   portmapper
  100000    2    tcp    111   portmapper
  100000    3    tcp    111   portmapper
  100000    4    tcp    111   portmapper
  100003    2    tcp    2049  nfs
  100003    3    tcp    2049  nfs
  100003    2    udp    2049  nfs
  100003    3    udp    2049  nfs
  100003    4    tcp    2049  nfs
  100005    1    tcp    2049  mountd
  100005    2    tcp    2049  mountd
  100005    3    tcp    2049  mountd
  100005    1    udp    2049  mountd
  100005    2    udp    2049  mountd
  100005    3    udp    2049  mountd
  100021    1    tcp    2049  nlockmgr
  100021    2    tcp    2049  nlockmgr
  100021    3    tcp    2049  nlockmgr
  100021    4    tcp    2049  nlockmgr
  100021    1    udp    2049  nlockmgr
  100021    2    udp    2049  nlockmgr
  100021    3    udp    2049  nlockmgr
  100021    4    udp    2049  nlockmgr
  100024    1    tcp    2049  status
  100024    1    udp    2049  status
  
```

Result displaying an open NFS port and an NFS service running on it

NFS Enumeration Tools

RPCScan

RPCScan communicates with RPC services and **checks misconfigurations on NFS shares**

```
python3 rpc-scan.py 10.10.1.19 --rpc - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker/RPCScan
#python3 rpc-scan.py 10.10.1.19 --rpc
rpc://10.10.1.19:111 Portmapper
RPC services for 10.10.1.19:
portmapper (100000) 2 udp 111
portmapper (100000) 3 udp 111
portmapper (100000) 4 udp 111
portmapper (100000) 2 tcp 111
portmapper (100000) 3 tcp 111
portmapper (100000) 4 tcp 111
nfs (100003) 2 tcp 2049
nfs (100003) 3 tcp 2049
nfs (100003) 2 udp 2049
nfs (100003) 3 udp 2049
nfs (100003) 4 tcp 2049
mount demon (100005) 1 tcp 2049
mount demon (100005) 2 tcp 2049
mount demon (100005) 3 tcp 2049
mount demon (100005) 1 udp 2049
mount demon (100005) 2 udp 2049
mount demon (100005) 3 udp 2049
network lock manager (100021) 1 tcp 2049
network lock manager (100021) 2 tcp 2049
network lock manager (100021) 3 tcp 2049
network lock manager (100021) 4 tcp 2049
network lock manager (100021) 1 udp 2049
network lock manager (100021) 2 udp 2049
network lock manager (100021) 3 udp 2049
network lock manager (100021) 4 udp 2049 https://github.com
```

SuperEnum

SuperEnum includes a **script** that does the basic enumeration of any open port

```
./superenum - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker/SuperEnum
# ./superenum Running script
Enter IP List filename with path
Target.txt File containing target IP address

TCP Scan Started for IP: 10.10.1.19
UDP Scan Started for IP: 10.10.1.19

Testing for 10.10.1.19: 111
Testing for 10.10.1.19: 111, Tool: nmap_rpcinfo
Testing for 10.10.1.19: 111, Tool: rpcinfo
./superenum: line 116: rpcinfo: command not found
```

```
./superenum - Parrot Terminal
File Edit View Search Terminal Help

Testing for 10.10.1.19: 2049
Testing for 10.10.1.19: 2049, Tool: nmap_nfs-ls Open NFS Port
Testing for 10.10.1.19: 2049, Tool: nmap_nfs-statfs
Testing for 10.10.1.19: 2049, Tool: showmount https://github.com
```

LO#06: Demonstrate Different Techniques for SMTP and DNS Enumeration

SMTP Enumeration

- SMTP provides 3 built-in-commands:
 - 🔵 **VERFY** - Validates users
 - 🔵 **EXPN** - Shows the actual delivery addresses of aliases and mailing lists
 - 🔵 **RCPT TO** - Defines the recipients of a message
- SMTP servers respond differently to VRFY, EXPN, and RCPT TO commands for valid and invalid users, based on which we can **determine valid users on the SMTP server**
- Attackers can directly interact with SMTP via the telnet prompt and collect a **list of valid users** on the SMTP server



Using the SMTP VRFY Command

```
$ telnet 192.168.168.1 25
Trying 192.168.168.1...
Connected to 192.168.168.1.
Escape character is '^]'.
220 NYmailserver ESMTP Sendmail 8.9.3
HELO
501 HELO requires domain address
HELO x
250 NYmailserver Hello [10.0.0.86],
pleased to meet you
VERFY Jonathan
250 Super-User <Jonathan@NYmailserver>
VERFY Smith
550 Smith... User unknown
```

Using the SMTP EXPN Command

```
$ telnet 192.168.168.1 25
Trying 192.168.168.1...
Connected to 192.168.168.1.
Escape character is '^]'.
220 NYmailserver ESMTP Sendmail 8.9.3
HELO
501 HELO requires domain address
HELO x
250 NYmailserver Hello [10.0.0.86],
pleased to meet you
EXPN Jonathan
250 Super-User <Jonathan@NYmailserver>
EXPXN Smith
550 Smith... User unknown
```

Using the SMTP RCPT TO Command

```
$ telnet1 192.168.168.1 25
Trying 192.168.168.1 ...
Connected to 192.168.168.1.
Escape character is '^]'.
220 NYmailserver ESMTP Sendmail 8.9.3
HELO
501 HELO requires domain address
HELO x
250 NYmailserver Hello [10.0.0.86], pleased
to meet you
MAIL FROM:Jonathan
250 Jonathan... Sender ok
RCPT TO:Ryder
250 Ryder... Recipient ok
RCPT TO: Smith
550 Smith... User unknown
```

SMTP Enumeration using Nmap and Metasploit

Nmap

Attackers perform enumeration on the target SMTP server using various **SMTP commands** available with NSE scripts

```
nmap -p 25 --script=smtp-enum-users 10.10.1.19 - Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ sudo su
[sudo] password for attacker:
[root@parrot:~/home/attacker]# nmap -p 25 --script=smtp-enum-users 10.10.1.19
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-30 01:17 EDT
Nmap scan report for www.moviescope.com (10.10.1.19)
Host is up (0.00070s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
| smtp-enum-users:
|   root
|   admin
|   administrator
|   webadmin
|   sysadmin
|   netadmin
|   guest
|   user
|   web
|   test
MAC Address: 02:15:5D:19:19:A3 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds
```

<https://nmap.org>

Metasploit

The Metasploit framework contains an **SMTP enumeration module** that allows attackers to connect to the target SMTP server and **enumerate usernames** using the predefined wordlists

```
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
msf6 auxiliary(smtp_enum) > run

[*] 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)

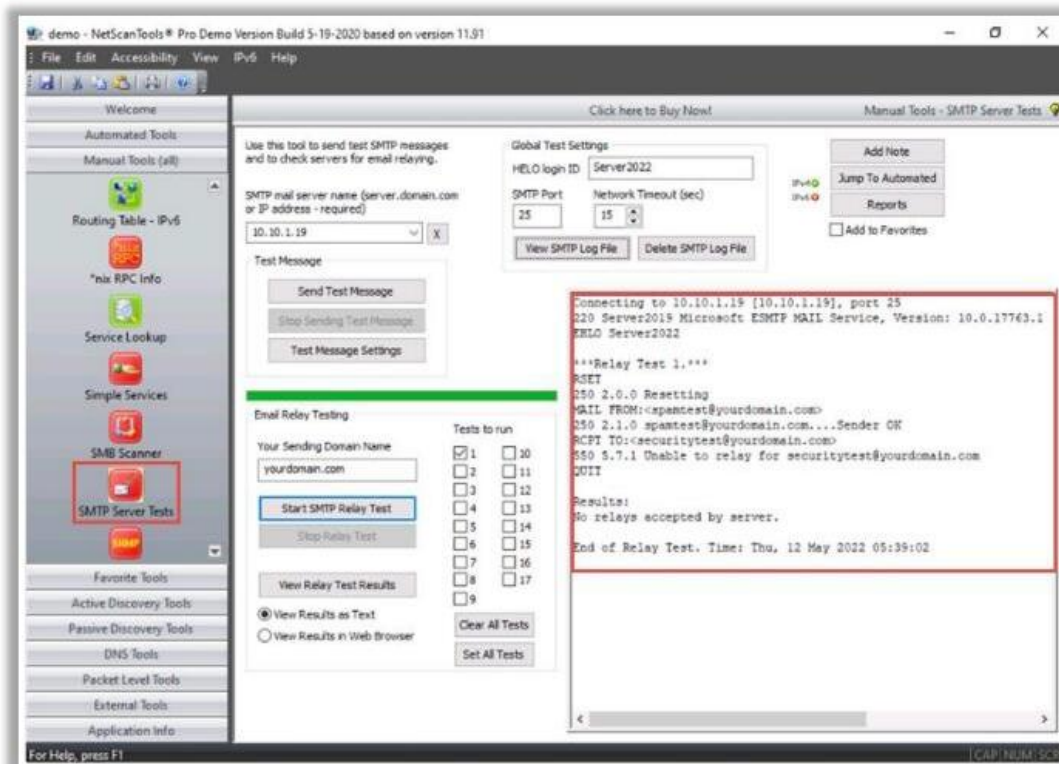
[*] Domain Name: localdomain
[+] 192.168.1.56:25 - Found user: ROOT
[+] 192.168.1.56:25 - Found user: backup
[+] 192.168.1.56:25 - Found user: bin
[+] 192.168.1.56:25 - Found user: daemon
[+] 192.168.1.56:25 - Found user: distccd
[+] 192.168.1.56:25 - Found user: ftp
[+] 192.168.1.56:25 - Found user: games
[+] 192.168.1.56:25 - Found user: gnats
[+] 192.168.1.56:25 - Found user: irc
[+] 192.168.1.56:25 - Found user: libuuid
[+] 192.168.1.56:25 - Found user: list
[+] 192.168.1.56:25 - Found user: lp
[+] 192.168.1.56:25 - Found user: mail
```

<https://www.metasploit.com>

SMTP Enumeration Tools

NetScan Tools Pro

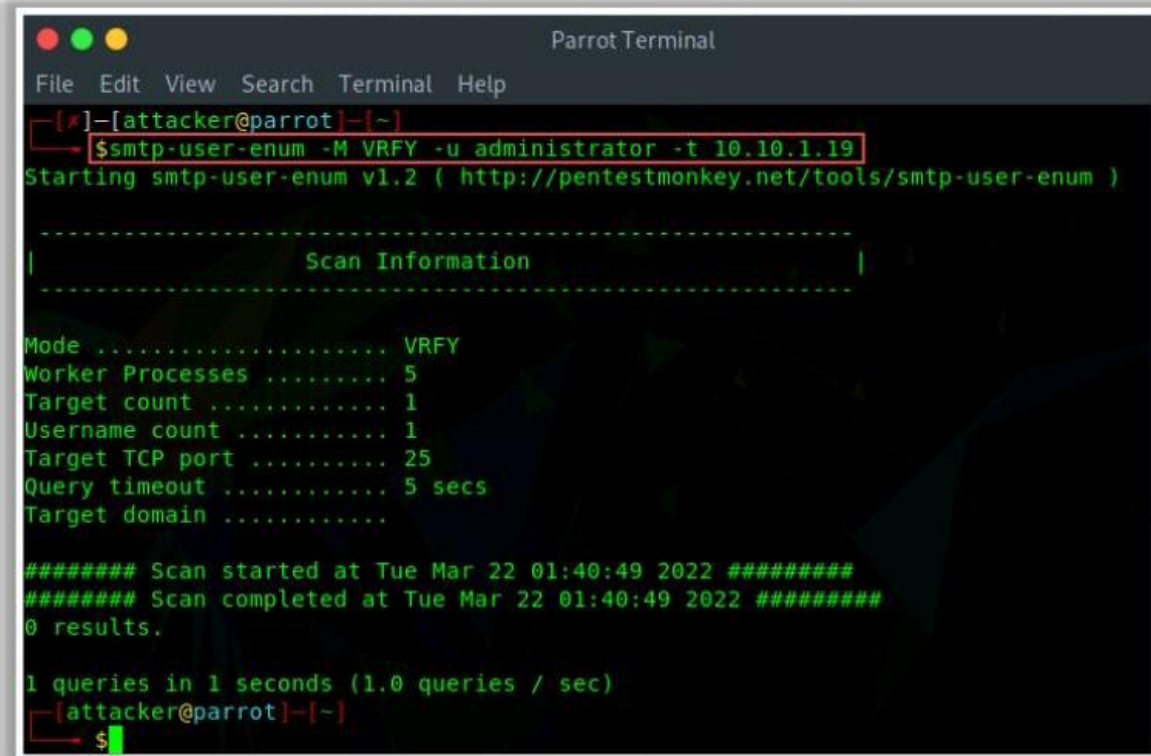
- NetScanTools Pro's SMTP Email Generator tool tests the process of sending an email message through an **SMTP server**



<https://www.netscantools.com>

smtp-user-enum

- It is a tool for **enumerating OS-level user accounts** on Solaris via the SMTP service (sendmail)
- Enumeration is performed by inspecting the responses to **VERFY**, **EXPN**, and **RCPT TO** commands



<http://pentestmonkey.net>

DNS Enumeration Using Zone Transfer

- If the target DNS server allows zone transfers, then attackers use this technique to obtain **DNS server names, hostnames, machine names, usernames, IP addresses, aliases**, etc. assigned within a target domain
- Attackers perform DNS zone transfer using tools, such as **nslookup**, **dig**, and **DNSRecon**; if DNS transfer setting is enabled on the target name server, it will provide DNS information, or else it will return an error saying it has failed or refuses the zone transfer

Linux DNS zone transfer using dig command

```
Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ dig ns www.certifiedhacker.com

;<<>> DiG 9.16.22-Debian <<>> ns www.certifiedhacker.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 7811
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:;, udp: 512
;; QUESTION SECTION:
;www.certifiedhacker.com.      IN      NS

;; ANSWER SECTION:
www.certifiedhacker.com. 14400 IN      CNAME  certifiedhacker.com.
certifiedhacker.com.    21600 IN      NS      ns1.bluehost.com.
certifiedhacker.com.    21600 IN      NS      ns2.bluehost.com.

;; Query time: 44 msec
;; SERVER: 8.8.8.8#53(8.8.8.8)
;; WHEN: Tue Mar 22 02:20:56 EDT 2022
;; MSG SIZE rcvd: 111

[attacker@parrot:~]$ dig @ns1.bluehost.com www.certifiedhacker.com axfr

;<<>> DiG 9.16.22-Debian <<>> @ns1.bluehost.com www.certifiedhacker.com axfr
;; (1 server found)
;; global options: +cmd
; Transfer failed.
```

Windows DNS zone transfer using nslookup command

```
Administrator: Command Prompt - nslookup
C:\Users\Administrator>nslookup
Default Server: dns.google
Address: 8.8.8.8

> set querytype=soa
> certifiedhacker.com
Server: dns.google
Address: 8.8.8.8

Non-authoritative answer:
certifiedhacker.com
    primary name server = ns1.bluehost.com
    responsible mail addr = dnsadmin.box5331.bluehost.com
    serial = 2018011205
    refresh = 86400 (1 day)
    retry = 7200 (2 hours)
    expire = 3600000 (41 days 16 hours)
    default TTL = 300 (5 mins)

> ls -d ns1.bluehost.com
[dns.google]
*** Can't list domain ns1.bluehost.com: Server failed
The DNS server refused to transfer the zone ns1.bluehost.com to your computer. If this
is incorrect, check the zone transfer security settings for ns1.bluehost.com on
the DNS
server at IP address 8.8.8.8.
```

DNS Cache Snooping

■ DNS cache snooping is a **DNS enumeration** technique whereby an **attacker queries** the **DNS server** for a specific cached DNS record

Non-recursive Method

Attackers send a **non-recursive query** by setting the **Recursion Desired (RD)** bit in the query header to zero

```

Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot ~]
$dig @162.159.25.175 certifiedhacker.com A +norecurse

<<>> DiG 9.16.22-Debian <<>> @162.159.25.175 certifiedhacker.com A +norecurse
(1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 32759
;; flags: qr aa; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;; certifiedhacker.com.      IN      A
;;
;; ANSWER SECTION:
certifiedhacker.com. 14400 IN      A      162.241.216.11

;; Query time: 36 msec
;; SERVER: 162.159.25.175#53(162.159.25.175)
;; WHEN: Tue Mar 22 03:23:49 EDT 2022
;; MSG SIZE rcvd: 64
  
```

Indicates that the query is accepted, but the site is not cached

Recursive Method

Attackers send a recursive query to **determine the time** the **DNS record** resides in the cache

```

Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot ~]
$dig @162.159.25.175 certifiedhacker.com A +recurse

<<>> DiG 9.16.22-Debian <<>> @162.159.25.175 certifiedhacker.com A +recurse
(1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 60606
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;; certifiedhacker.com.      IN      A
;;
;; ANSWER SECTION:
certifiedhacker.com. 14400 IN      A      162.241.216.11

;; Query time: 36 msec
;; SERVER: 162.159.25.175#53(162.159.25.175)
;; WHEN: Tue Mar 22 03:43:34 EDT 2022
;; MSG SIZE rcvd: 64
  
```

A high TTL value indicates that the record was not in the cache

DNSSEC Zone Walking

- DNSSEC zone walking is a DNS enumeration technique where an attacker attempts to **obtain internal records of the DNS server** if the DNS zone is not properly configured
- Attackers use tools, such as **LDNS** and **DNSRecon**, to exploit this vulnerability and **obtain the network information** of a target domain and further launch Internet-based attacks

LDNS

```
ubuntu@ubuntu-Virtual-Machine: ~  
ubuntu@ubuntu-Virtual-Machine:~$ ldns-walk @8.8.8.8 iana.org  
iana.org.      iana.org. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY  
api.iana.org.  CNAME RRSIG NSEC  
app.iana.org.  CNAME RRSIG NSEC  
autodiscover.iana.org. CNAME RRSIG NSEC  
beta.iana.org. CNAME RRSIG NSEC  
blackhole-1.iana.org. A AAAA RRSIG NSEC  
blackhole-2.iana.org. A AAAA RRSIG NSEC  
blackhole-3.iana.org. AAAA RRSIG NSEC  
blackhole-4.iana.org. AAAA RRSIG NSEC  
_dnsauth.data.iana.org. TXT RRSIG NSEC  
datatracker.iana.org. CNAME RRSIG NSEC  
dev.iana.org.  CNAME RRSIG NSEC  
feedback.iana.org. CNAME RRSIG NSEC  
ftp.iana.org.  CNAME RRSIG NSEC  
vhost-int.int.iana.org. CNAME RRSIG NSEC  
itar.iana.org. A AAAA RRSIG NSEC  
maintenance.iana.org. CNAME RRSIG NSEC  
number-6.iana.org. AAAA RRSIG NSEC  
pen.iana.org.  CNAME RRSIG NSEC  
ppa-request.iana.org. MX RRSIG NSEC  
prisoner.iana.org. A AAAA RRSIG NSEC  
rdap.iana.org. CNAME RRSIG NSEC  
rdap-qa.iana.org. A RRSIG NSEC  
recursive.iana.org. A AAAA RRSIG NSEC
```

**Enumerated
DNS record file**

<https://www.nlnetlabs.nl>

DNSRecon

```
./dnsrecon.py -d www.certifiedhacker.com -z - Parrot Terminal  
File Edit View Search Terminal Help  
crt: Perform crt.sh search for subdomains and hosts.  
snoop: Perform cache snooping against all NS servers for a given domain, testing  
all with file containing the domains, file given with -D option  
tld: Remove the TLD of given domain and test against all TLDs registered in IANA.  
zonewalk: Perform a DNSSEC zone walk using NSEC records.  
[root@parrot:~/home/attacker/dnsrecon]  
#./dnsrecon.py -d www.certifiedhacker.com -z  
[*] std: Performing General Enumeration against: www.certifiedhacker.com...  
[-] DNSSEC is not configured for www.certifiedhacker.com  
[*] SOA ns1.bluehost.com 162.159.24.80  
[*] NS ns1.bluehost.com 162.159.24.80  
[*] NS ns2.bluehost.com 162.159.25.175  
[*] MX mail.certifiedhacker.com 162.241.216.11  
[*] CNAME www.certifiedhacker.com certifiedhacker.com  
[*] A certifiedhacker.com 162.241.216.11  
[*] TXT www.certifiedhacker.com v=spf1 a mx ptr include:bluehost.com ?all  
[*] Enumerating SRV Records  
[+] 0 Records Found  
[*] Performing NSEC Zone Walk for www.certifiedhacker.com  
[*] Getting SOA record for www.certifiedhacker.com  
[*] Name Server 162.159.24.80 will be used  
[*] CNAME www.certifiedhacker.com certifiedhacker.com  
[*] A certifiedhacker.com 162.241.216.11  
[+] 2 records found
```

<https://www.github.com>

DNS and DNSSEC Enumeration Using Nmap

DNS Enumeration

Attackers use Nmap for scanning domains and obtaining a **list of subdomains, records, IP addresses**, and other valuable information from the target host

```
Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$ nmap --script=broadcast-dns-service-discovery certifiedhacker.com
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 04:26 EDT
Pre-scan script results:
| broadcast-dns-service-discovery:
|   224.0.0.251
|   5555/tcp adb
|_   Address=10.10.1.3 fe80::cbac:552e:b75a:c59
Nmap scan report for certifiedhacker.com (162.241.216.11)
Host is up (0.031s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com
Not shown: 649 filtered tcp ports (no-response), 337 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
443/tcp   open  https
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
2000/tcp  open  cisco-sccp
2222/tcp  open  EtherNetIP-1
3306/tcp  open  mysql
5060/tcp  open  sip
Nmap done: 1 IP address (1 host up) scanned in 10.44 seconds
```

DNSSEC Enumeration

Attackers enumerate DNSSEC using Nmap **dns-nsec-enum.nse** or **dns-nsec3-enum.nse** scripts to obtain information related to domains and their sub-domains

```
nmap -sU -p 53 --script dns-nsec-enum --script-args dns-nsec-enum.domains=c
File Edit View Search Terminal Help
[root@parrot]~/home/attacker$ #nmap -sU -p 53 --script dns-nsec-enum --script-args dns-nsec-enum.
domains=certifiedhacker.com 162.159.25.175
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 05:35 EDT
Nmap scan report for ns2.bluehost.com (162.159.25.175)
Host is up (0.0025s latency).

PORT      STATE SERVICE
53/udp    open  domain
| dns-nsec-enum:
|_  No NSEC records found
Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
```

DNS Enumeration Tools

Knock
<https://github.com>

Subfinder
<https://github.com>

Raccoon
<https://github.com>

TurboList3r
<https://github.com>

LO#07: Demonstrate IPsec, VoIP, RPC, Unix/Linux, Telnet, FTP, TFTP, SMB, IPv6, and BGP Enumeration

IPsec Enumeration

- IPsec uses Encapsulation Security Payload (ESP), Authentication Header (AH), and Internet Key Exchange (IKE) to secure **communication between virtual private network (VPN) end points**
- Most IPsec based **VPNs use Internet Security Association and Key Management Protocol (ISAKMP)**, a part of IKE, to establish, negotiate, modify, and delete Security Associations (SA) and cryptographic keys in a VPN environment
- A simple **scanning for ISAKMP at UDP port 500** can indicate the presence of a VPN gateway
- Attackers can probe further using a tool, such as **ike-scan**, to enumerate sensitive information, including encryption and hashing algorithm, authentication type, key distribution algorithm, and SA LifeDuration

```
nmap -sU -p 500 10.10.10.10 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#nmap -sU -p 500 10.10.10.10
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 10:07:00
Nmap scan report for 10.10.10.10
Host is up (0.060s latency).

PORT      STATE SERVICE
500/udp   open  isakmp

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
[root@parrot]~/home/attacker
#
```

```
ike-scan -M 10.10.10.10 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#ike-scan -M 10.10.10.10
Starting ike-scan 1.9.4 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.10.10 Main Mode Handshake returned
HDR=(CKY-R=8b077cfd0082b0be)
SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration
(4)=0x00007080)
VID=1e2b516905991c7d7c96fcbfb587e46100000009 (Windows-8)
VID=4a131c81070358455c5728f20e95452f (RFC 3947 NAT-T)
VID=90cb80913ebb696e086381b5ec427b1f (draft-ietf-ipsec-nat-t-ike-02\n)
VID=4048b7d56ebce88525e7de7f00d6c2d3 (IKE Fragmentation)
VID=fblde3cdf341b7ea16b7e5be0855f120 (MS-Negotiation Discovery Capable)
VID=e3a5966a76379fe707228231e5ce8652 (IKE CGA version 1)

Ending ike-scan 1.9.4: 1 hosts scanned in 0.076 seconds (13.10 hosts/sec). 1 returned
handshake; 0 returned notify
```

VoIP Enumeration

- VoIP uses **Session Initiation Protocol (SIP)** protocol to enable voice and video calls over an IP network
- SIP service generally uses **UDP/TCP ports 2000, 2001, 5060, and 5061**
- VoIP enumeration provides sensitive information, such as **VoIP gateway/servers, IP-PBX systems, client software** (softphones)/VoIP phones, User-agent IP addresses, and **user extensions**
- This information can be used to launch various VoIP attacks, such as **Denial-of-Service (DoS)**, Session Hijacking, **Caller ID spoofing, Eavesdropping**, Spamming over Internet Telephony (SPIT), and **VoIP phishing** (Vishing)

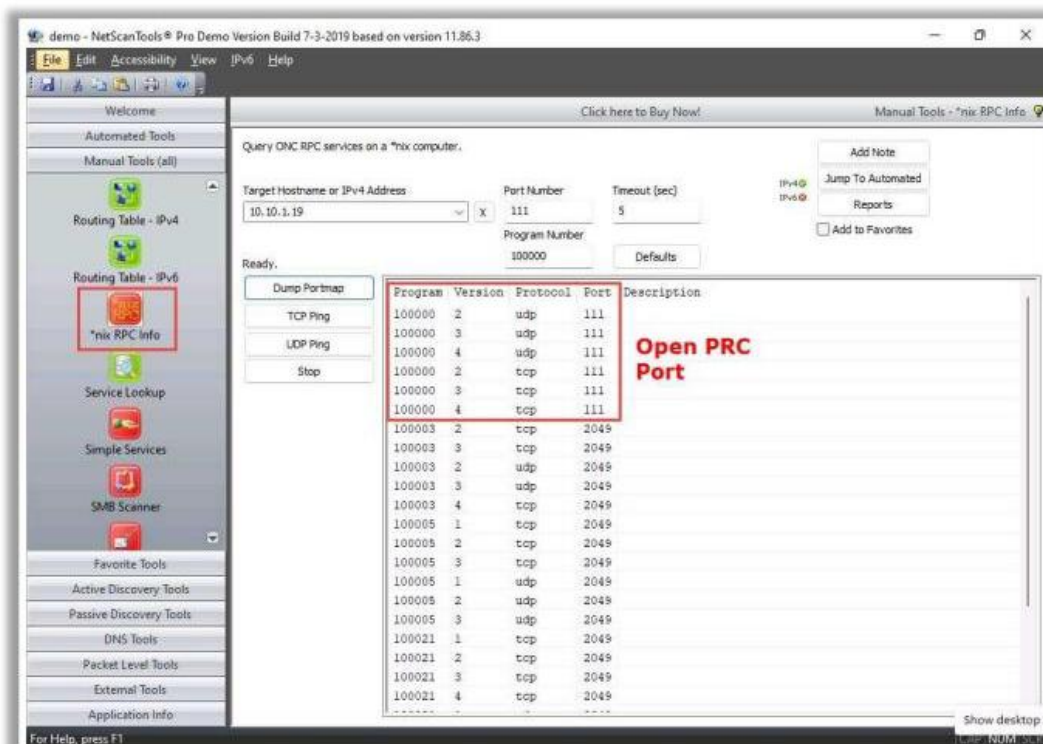
```
svmap 192.168.0.1/24 - Parrot Terminal
File Edit View Search Terminal Help
-[root@parrot]-[/home/attacker]
#svmap 192.168.0.1/24
-----+-----+-----+
| SIP Device      | User Agent      | Fingerprint      |
+-----+-----+-----+
| 192.168.0.113:5060 | DLink VoIP Stack | disabled          |
+-----+-----+-----+
```

```
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
msf > use auxiliary/scanner/sip/enumerator
msf auxiliary(enumerator) > use auxiliary/scanner/sip/options
msf auxiliary(options) > set RHOSTS 192.168.0.1/24
RHOSTS => 192.168.0.1/24
msf auxiliary(options) > run

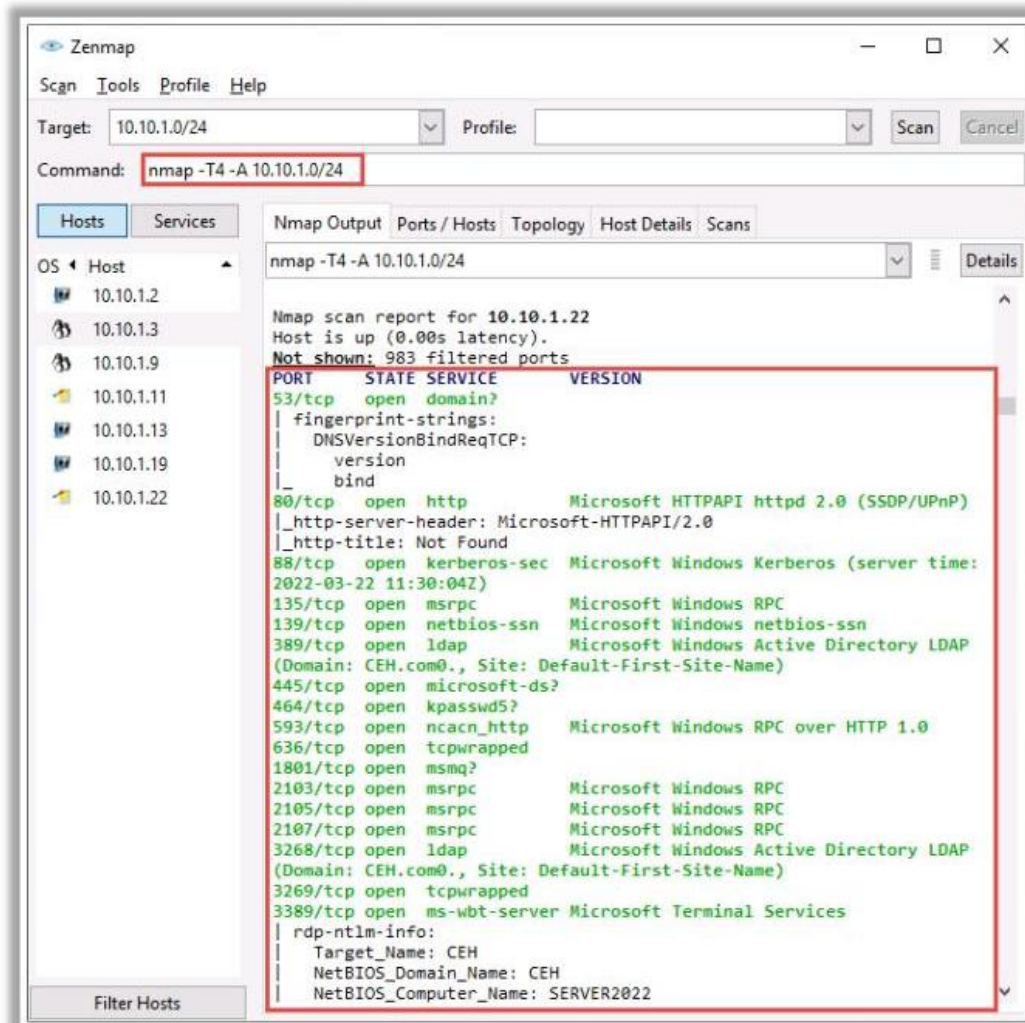
[*] Sending SIP UDP OPTIONS requests to 192.168.0.0->192.168.0.255 (256 hosts)
[*] 192.168.0.54:5060 udp SIP/2.0 200 OK: {"User-Agent"=>"Grandstream GXP1620 1.0.2.27", "Allow"=>"INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE"}
[*] 192.168.0.87:5060 udp SIP/2.0 200 OK: {"User-Agent"=>"Grandstream GXP1620 1.0.2.27", "Allow"=>"INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE"}
[*] 192.168.0.109:5060 udp SIP/2.0 200 OK: {"User-Agent"=>"Grandstream GXP1620 1.0.2.27", "Allow"=>"INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE"}
[*] 192.168.0.113:5060 udp SIP/2.0 200 OK: {"User-Agent"=>"Grandstream GXP1620 1.0.2.27", "Allow"=>"INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE"}
[*] 192.168.0.167:5060 udp SIP/2.0 200 OK: {"User-Agent"=>"Grandstream GXP1620 1.0.4.33", "Allow"=>"INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE"}
[*] Scanned 256 of 256 hosts (100% complete)
[*] Auxiliary module execution completed
```

RPC Enumeration

- Remote Procedure Call (RPC) allows clients and servers to communicate in **distributed client/server programs**
- Enumerating RPC endpoints enables attackers to **identify any vulnerable services** on these service ports



<https://www.netscantools.com>



Unix/Linux User Enumeration

rusers

- Displays a list of users who are logged on to remote machines or machines on local network

Syntax: `/usr/bin/rusers [-a] [-l] [-u| -h| -i] [Host ...]`

rwho

- Displays a list of users who are logged on to hosts on the local network

Syntax: `rwho [ -a]`

finger

- Displays information about system users, such as login name, real name, terminal name, idle time, login time, office location, and office phone numbers

Syntax: `finger [-l] [-m] [-p] [-s] [user ...] [user@host ... ]`



```

ubuntu@ubuntu-Virtual-Machine: ~
ubuntu@ubuntu-Virtual-Machine:~$ finger
Login      Name      Tty      Idle  Login Time   Office   Office Phone
ubuntu    Ubuntu    *:1             May 12 08:04 (:1)
ubuntu@ubuntu-Virtual-Machine:~$ finger ubuntu
Login: ubuntu      Name: Ubuntu
Directory: /home/ubuntu  Shell: /bin/bash
On since Thu May 12 08:04 (EDT) on :1 from :1 (messages off)
No mail.
No Plan.
ubuntu@ubuntu-Virtual-Machine:~$

```



Telnet and SMB Enumeration

Telnet Enumeration

- If the Telnet port is found open, attackers can **access shared information**, including the hardware and software information of the target
- Telnet enumeration enables attackers to **exploit identified vulnerabilities** and perform brute-force attacks to gain unauthorized access to the target and launch further attacks

```
nmap -p 23 10.10.1.22 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#nmap -p 23 10.10.1.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 07:08:00
Nmap scan report for 10.10.1.22
Host is up (0.0011s latency).

PORT      STATE      SERVICE
23/tcp    filtered  telnet
MAC Address: 00:15:5d:77:8d:25 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
```

Indicates that port 23 is blocked by a firewall or some other network obstacle

SMB Enumeration

- Attackers use SMB enumeration tools, such as **Nmap**, **SMBMap**, **enum4linux**, and **nulllinux**, to perform a directed scan on the SMB service running on port 445
- SMB enumeration helps attackers to perform **OS banner grabbing** on the target

```
nmap -p 445 -A 10.10.1.19 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/
#nmap -p 445 -A 10.10.1.19
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 00:00:00
Nmap scan report for www.moviescope.com (10.10.1.19)
Host is up (0.0014s latency).

PORT      STATE      SERVICE      VERSION
445/tcp    open      microsoft-ds?

MAC Address: 00:15:5d:77:8d:25 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Windows 10 1709 - 1909 (96%), Microsoft Windows 10 1709 - 1803 (94%), Microsoft Windows Server 2012 (92%), Microsoft Windows Vista SP1 (92%), Microsoft Windows Longhorn (92%), Microsoft Windows 7, Windows Server 2012, or Windows 8.1 Update 1 (91%), Microsoft Windows Server 2012 or Server 2012 R2 (90%), Microsoft Windows Server 2012 R2 Update 1 (90%), Microsoft Windows Server 2016 (90%), Microsoft Windows Server 2016 build 10586 - 14393 (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Host script results:
|_ nbstat: NetBIOS name: SERVER2019, NetBIOS user: <unknown>, NetBIOS MAC: 00:15:5d:77:8d:25 (Microsoft)
|_ smb2-time:
|   date: 2022-03-22T12:08:57
|   start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required

TRACEROUTE
HOP RTT ADDRESS
1 1.43 ms www.moviescope.com (10.10.1.19)
```

Open port 445

SMB details

FTP and TFTP Enumeration

FTP Enumeration

- FTP transfers data in plain text between the sender and receiver, which can lead to critical information, such as **usernames and passwords, being exposed to attackers**
- Attackers use **Nmap** to scan and enumerate open port 21 by running FTP services and further use the information to launch various attacks, such as **FTP bounce, FTP brute force, and packet sniffing**

```
nmap -p 21 www.certifiedhacker.com - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~# nmap -p 21 www.certifiedhacker.com
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 00:01 CDT
Nmap scan report for www.certifiedhacker.com (162.241.216.11)
Host is up (0.035s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com

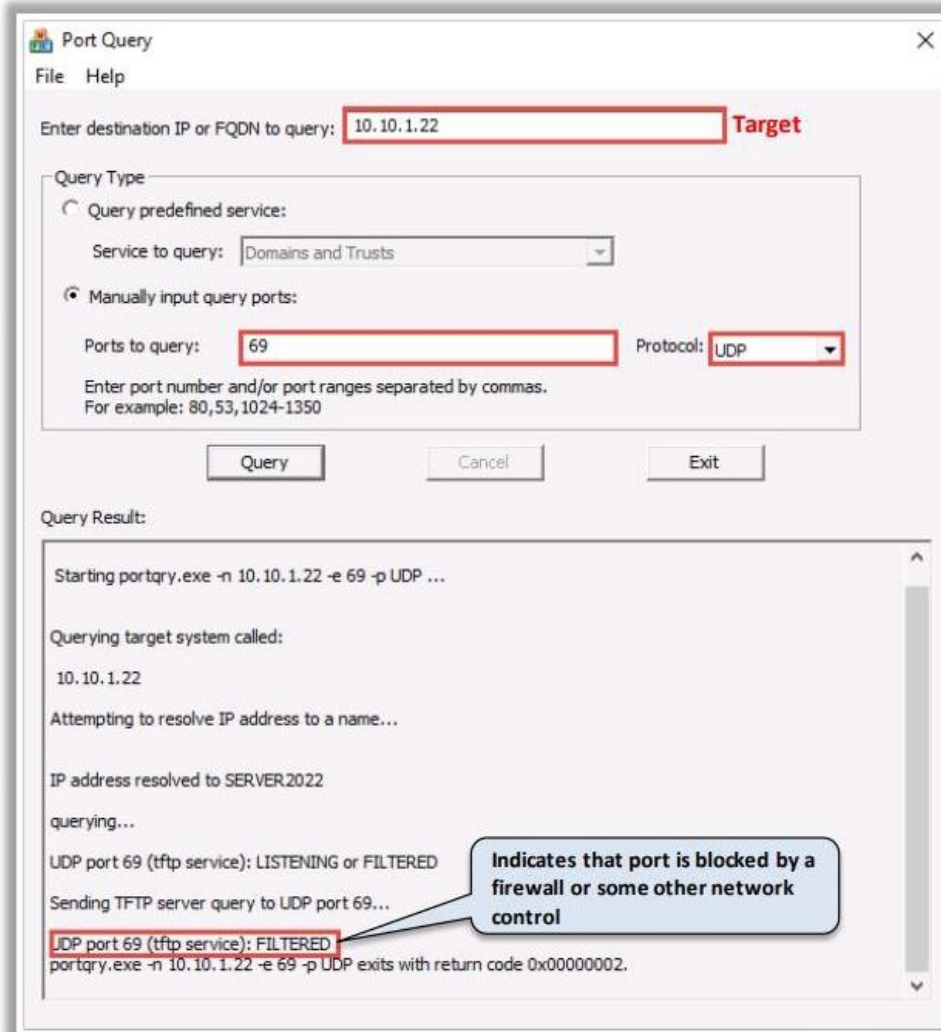
PORT      STATE SERVICE
21/tcp    open  ftp

Nmap done: 1 IP address (1 host up) scanned in 0.32 seconds
```

Port 21 is open which makes the data accessible to external sources

TFTP Enumeration

- Attackers perform TFTP enumeration using tools, such as **PortQry** and **Nmap**, to extract information, such as **running TFTP services** and files stored on the remote server
- Using this information, attackers can gain unauthorized access to the target system, steal important files, and upload malicious script to launch further attacks



- ## IPv6 Hackit

<https://github.com>

<http://ipv6hackit.sourceforge.net>

BGP Enumeration

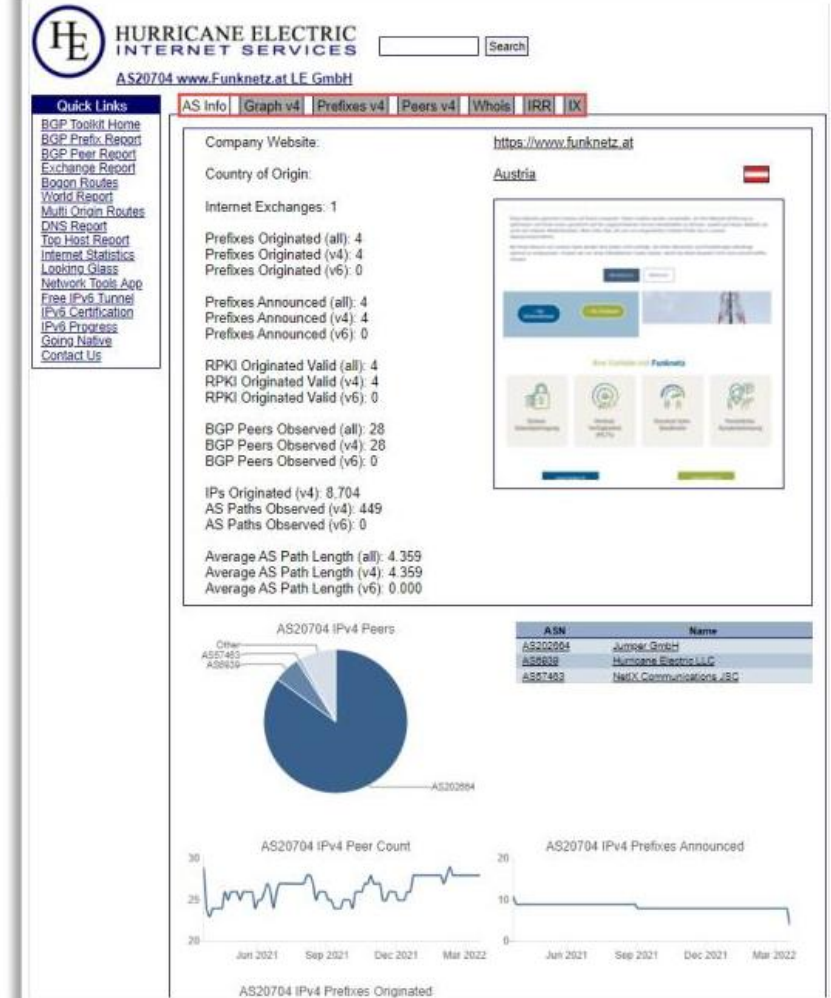
- Border Gateway Protocol (BGP) is a routing protocol used to **exchange routing and reachability information** between different autonomous systems (AS) present on the Internet
- Attackers perform BGP enumeration using tools, such as **Nmap** and **BGP Toolkit**, to discover the IPv4 prefixes announced by the AS number and routing path followed by the target
- Attackers use this information to launch various attacks, such as **man-in-the-middle attack**, **BGP hijacking attack**, and **DoS attack** against the target

```

nmap -p 179 100.100.100.73 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/ip666]
#nmap -p 179 100.100.100.73
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-22 00:30:20
Nmap scan report for 100.100.100.73
Host is up (0.18s latency).

PORT      STATE SERVICE
179/tcp   open  bgp

Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
  
```



<https://bgp.he.net>

LO#08: Explain Enumeration Countermeasures

Enumeration Countermeasures

SNMP

- **Remove the SNMP agent** or turn off the SNMP service
- If turning off SNMP is not an option, then change the default **community string names**
- **Upgrade to SNMP3**, which encrypts passwords and messages
- Implement the Group Policy security option called **"Additional restrictions for anonymous connections"**

LDAP

- By default, LDAP traffic is transmitted unsecured; **use SSL or STARTTLS technology** to encrypt the traffic
- Select a **username different** from your email address and enable **account lockout**
- Use **NT LAN Manager (NTLM)**, **Kerberos**, or any basic authentication mechanism to limit access to legitimate users

NFS

- Implement **proper permissions** (read/write must be restricted to specific users) on exported file systems
- Implement **firewall rules** to block NFS port 2049
- Ensure **proper configuration** of files, such as `/etc/smb.conf`, `/etc/exports` and `etc/hosts.allow`, to protect the data stored in servers
- **Log the requests** to access the system files on the NFS server

Enumeration Countermeasures (Cont'd)

SMTP

Configure SMTP servers to

- Ignore **email messages** to unknown recipients
- Exclude sensitive **mail server** and **local host information** in mail responses
- Disable **open relay** feature
- **Limit the number of accepted connections** from a source to prevent brute-force attacks

SMB

- Disable SMB protocol on **Web and DNS Servers**
- Disable SMB protocol on **Internet facing servers**
- Disable ports **TCP 139** and **TCP 445** used by the SMB protocol
- Restrict anonymous access through **RestrictNullSessAccess** parameter from the **Windows Registry**

FTP

- Implement **secure FTP** (SFTP) or FTP secure (FTPS) to encrypt the FTP traffic over the network
- Implement **strong passwords** or a certification-based authentication policy
- Ensure that **unrestricted uploading of files** on the FTP server is **not allowed**
- **Disable anonymous FTP accounts**; if not feasible, regularly monitor anonymous FTP accounts

DNS Enumeration Countermeasures

1 Restrict resolver access

6 Restrict DNS zone transfers

11 Use VPN

2 Randomize source ports

7 Separate resolver and authoritative nameserver

12 Implement two-factor authentication

3 Audit DNS zones

8 Use isolated DNS servers

13 Use DNS change lock

4 Patch known vulnerabilities

9 Disable DNS recursion

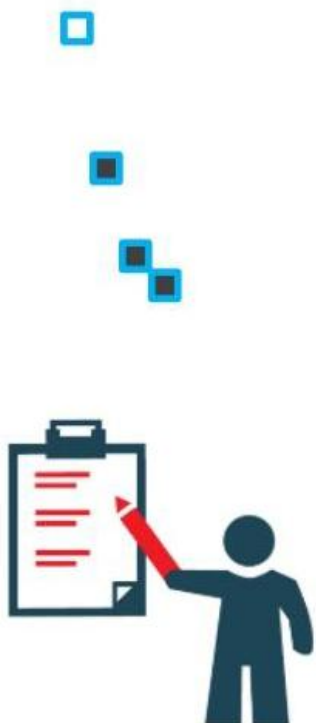
14 Use DNSSEC

5 Monitor nameservers

10 Harden the OS

15 Use premium DNS registration

Module Summary



- ❑ In this module, we have discussed the following:
 - Enumeration concepts along with techniques, services, and ports used for enumeration
 - How attackers perform enumeration using different techniques (NetBIOS, SNMP, LDAP, AD, NTP, NFS, SMTP, DNS, IPsec, VoIP, RPC, Linux/Unix, Telnet, FTP, TFTP, SMB, IPv6, and BGP enumeration) to gather more information about a target
 - How organizations can defend against enumeration activities
- ❑ In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen testers, perform vulnerability analysis to identify security loopholes in the target organization's network, communication infrastructure, and end systems